

V.I.P.E.R. — Architecture & Security Overview

Product: V.I.P.E.R. (Versatile Investigative Platform for Enforcement Records) **Vendor:** Intellect LE, LLC
Document Version: 1.0 **Applies to:** VIPER v4.0.8 **Companion to:** VIPER_NIST_CSF_Policy_Guide.md · VIPER_Data_Flow_and_Integrations.md **Audience:** Agency IT, CJIS Systems Officer (CSO)/LASO, security architects, risk & audit reviewers

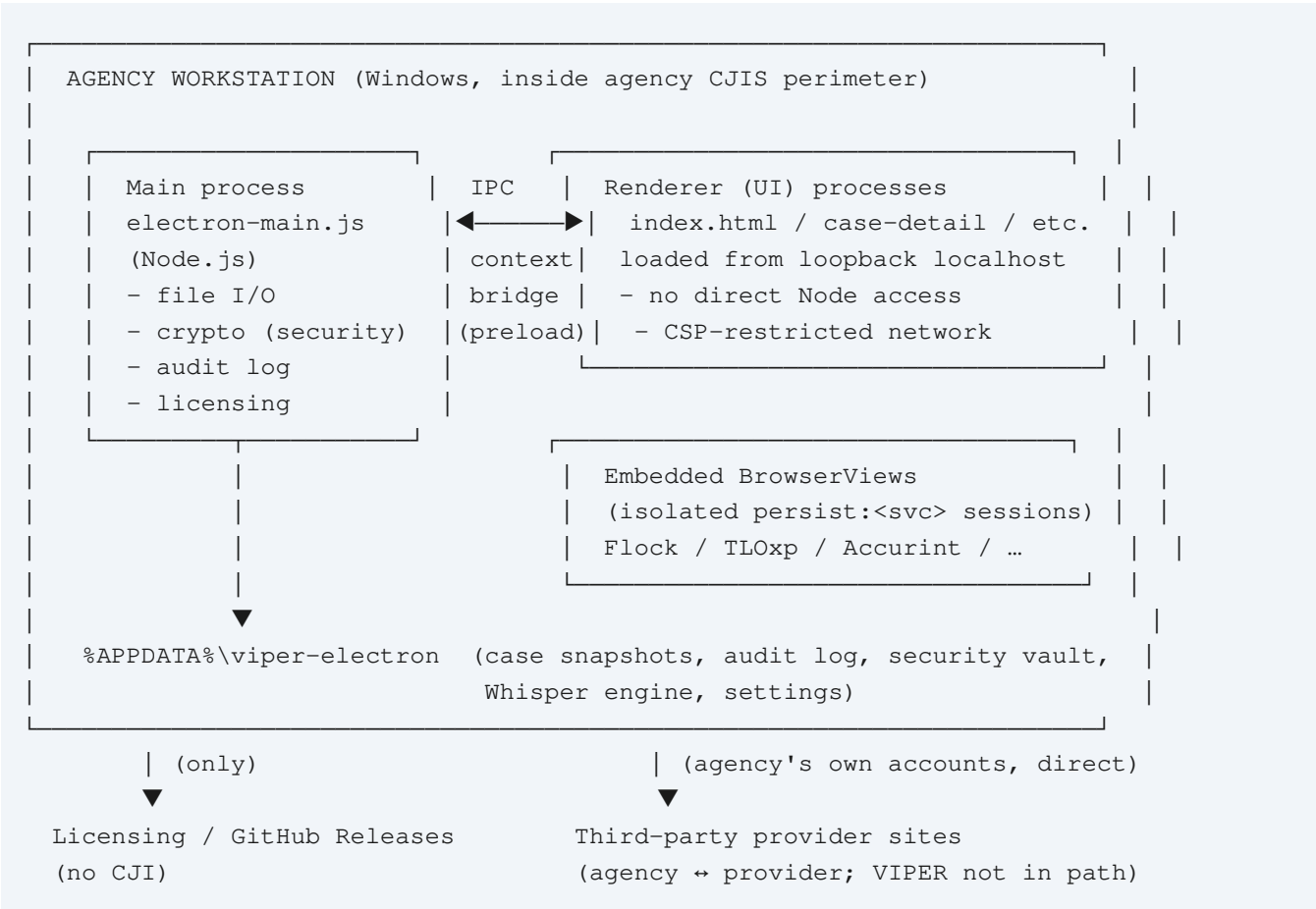
1. Executive summary

VIPER is a **locally-installed Windows desktop application** (Electron) licensed as a **one-time, perpetual, per-user purchase** — not a subscription and not a hosted service. All case data is created and stored **on the agency's own device**, inside the agency's existing CJIS perimeter. **Intellect LE operates no cloud service that receives, stores, processes, or has access to agency CJI.** The vendor's only online endpoints handle license validation and signed software distribution, neither of which carries case content.

This document describes the runtime architecture, data-at-rest and in-transit posture, identity model, auditing, supply-chain integrity, and trust boundaries — and maps them to the specific control questions raised in agency security review.

2. Runtime architecture

VIPER is an Electron application composed of three isolated tiers:



- **Main process** (`electron-main.js`, `Node.js`): owns all filesystem access, cryptography, audit logging, licensing, and window management. Serves renderer pages from a **loopback-only** HTTP server (`localhost:8000`) — not bound to any external interface.
- **Renderer processes** (the HTML/JS UI): run without direct Node integration; they reach privileged operations only through a **contextBridge** surface defined in `preload.js`. Outbound network is constrained by a per-page **Content-Security-Policy**.
- **Embedded BrowserViews**: third-party provider websites rendered in **isolated session partitions** (`persist:flock`, `persist:tlo`, ...). See `VIPER_Data_Flow_and_Integrations.md` (Category C).

3. Data at rest

All agency data resides under `%APPDATA%\viper-electron` on the local device:

Store	Contents	Protection
Case snapshots (<code>cases/<n>/case-snapshot.json</code>) + <code>localStorage</code>	Case records, evidence metadata, narratives	Optional Field Security (AES-256-GCM); baseline device BitLocker
<code>audit.log</code> (+ rotated <code>.1-5</code>)	Tamper-evident audit trail	Append-only hash chain; optionally AES-256-GCM encrypted when Field Security is unlocked
<code>security.json</code> , <code>vault.enc</code>	Field-security config & wrapped master key	Master key wrapped by user passphrase and recovery key
<code>engines/whisper*</code>	On-demand local transcription engine	Runs fully offline; no data egress
Exports (<code>.pulse</code> , <code>.vcase</code> , <code>.vbak</code>)	Agency-initiated case exports	<code>.pulse</code> = AES-256-CBC + PBKDF2 (100k, SHA-256)

Cryptography (module `security.js`):

- Algorithm: **AES-256-GCM** (authenticated encryption)
- Key derivation: **PBKDF2**, 100,000 iterations, SHA-256, 256-bit key
- Master key wrapped by both the user passphrase and a recovery key; **keys never leave the device** and are never known to the vendor
- Envelope format `VIPENC` (magic + version + IV + auth tag)

Baseline recommendation: agencies run **BitLocker full-disk encryption** (FIPS-validated) on every VIPER workstation, which is the standard CJIS at-rest control for locally-stored CJI, layered beneath VIPER's own Field Security.

4. Data in transit

CJI does not transit to the vendor, so there is no vendor-side CJI-in-transit path. Concretely:

- **License validation & updates:** HTTPS/TLS to the licensing endpoint and GitHub Releases. Payloads contain licensing metadata and signed binaries only — **no case data**.

- **Embedded provider panels (Category C):** TLS sessions established **directly between the officer's authenticated session and the provider**. VIPER is not a party to, and does not decrypt, that traffic.
- **OSINT lookups (Category D):** HTTPS to public/registered services carrying only the officer-entered query term.
- **TRACE Network (Category B, opt-in):** HTTPS carrying **irreversible SHA-256 token hashes only**.
- **Supervisor Link (optional):** end-to-end **AES-256-GCM** (12-byte IV, appended auth tag; RFC 7638 JWK thumbprints) between agency-controlled endpoints.

Full inventory: `VIPER_Data_Flow_and_Integrations.md`.

5. Identity, authentication & MFA/SSO

Because VIPER runs inside the agency's authenticated Windows session, it **inherits the agency's endpoint identity controls**:

- **Primary authentication / MFA / SSO** are enforced at the agency identity layer — Windows domain / Windows Hello for Business / smartcard-PIV / Azure AD / Okta — which is the correct location for these controls on an on-premises application. VIPER does not operate a competing identity system or a vendor login.
- **Application-level lock:** VIPER additionally offers an optional passphrase lock (Field Security) that gates access to encrypted case data on the device.
- **Third-party services (Category C):** authenticated with the **agency's own accounts and their MFA**, on the provider's real login page.
- **No vendor-held credentials:** Intellect LE issues license keys, not user identities; it holds no user passwords and no CJI-system credentials.

6. Auditing & accountability (module `audit-log.js`)

- **Append-only, tamper-evident:** each entry carries `prev_hash` = hash of the prior entry's canonical form (root = `GENESIS`). Any edit or deletion breaks the chain and is detected by the built-in `verifyChain()` / Settings → Verify function.
- **Coverage:** app lifecycle, case lifecycle, evidence & warrant operations (create/modify/delete/export), security lock/unlock, license events, settings changes, update events — each with timestamp, user attribution, action type, and success/failure.
- **No plaintext CJI in the log:** records **that** an action happened (filenames, sizes, SHA-256s, case numbers) — not victim/suspect content.
- **Immutability from inside the app:** users cannot delete entries. Rotation is size-based (50 MB × 5 files); rotated files persist until agency IT removes them, so **retention is set by agency policy**.
- **Exportable to the agency SIEM/WORM store** for long-term, independent retention.

7. Software supply chain & patching

- **Distribution:** signed installers published to the official GitHub Releases channel for `exhonorated999/project-viper`.
- **Code signing:** Authenticode signature (signtool) applied to release binaries.
- **Update integrity:** the auto-updater (electron-updater) reads `latest.yml` and **verifies a SHA-512 hash** of the installer before applying — a tampered or substituted binary is rejected.
- **Provenance:** dependency manifest (`package-lock.json`) and `npm audit` reports are available per release; a Software Bill of Materials (SBOM) can be provided.
- **Patching model:** application security patches ship through the signed update channel. OS, driver, and endpoint patching remain the agency's standard endpoint-management responsibility (the "production environment" is the agency workstation, not a vendor server).

8. Trust boundaries & vendor scope

Concern	Owner	Rationale
CJI at rest / in use	Agency	Data lives only on agency devices
Endpoint MFA / SSO / access control	Agency	Enforced at Windows/IdP layer
SIEM / SOC monitoring	Agency	Monitors the endpoints/network where data resides
Backup / DR / RTO / RPO of CJI	Agency	No vendor-held copy exists to recover
Incident response & breach notification	Agency	Vendor has no visibility into affected data
Data return / destruction (NIST 800-88)	Agency	Vendor holds nothing to return or destroy
Third-party provider (Flock, Accurant, ...) data	Agency ↔ provider	Pre-existing CJIS agreements; VIPER not in path
Application code integrity & signed releases	Vendor	Build pipeline & code signing
License issuance / revocation	Vendor	Licensing metadata only
Timely security patches for the app	Vendor	Via signed update channel

Why not SOC 2? SOC 2 attests to a *service organization's* controls over a *hosted system* that stores/ processes customer data over a multi-month observation window. VIPER has **no hosted data plane** — the only in-scope "system" would be the build/release pipeline. The proportionate, more relevant evidence for locally-installed software is this architecture package plus, if desired, a **third-party application penetration test** with executive summary.

9. Mapping to agency review questions

Review item	Where addressed
Encryption at rest / in transit (AES-256+)	§3, §4 — AES-256-GCM (Field Security), AES-256-CBC (.pulse), TLS; BitLocker baseline

MFA / SSO	§5 — enforced at agency IdP; app-level lock available
Immutable audit logs (view/create/modify/delete)	§6 — append-only hash chain, verifiable
Log retention	§6 — agency-set; exportable to SIEM/WORM
SIEM / SOC	§8 — agency responsibility (data on agency endpoints)
Patching schedule	§7 — signed auto-update; OS patching = agency
Penetration testing	§8 — app pen test offered as right-sized artifact
Vulnerability scanning	§7 — dependency/SCA per release; endpoint scans = agency
Incident response / breach notification	§8 + NIST guide RS — agency-led; vendor has no data visibility
RTO / RPO / DR	§8 — agency backups; no vendor-held copy
Data return / destruction (NIST 800-88)	§8 — agency-controlled; vendor holds nothing
Third-party integrations (Flock, etc.)	§2, §8 + VIPER_Data_Flow_and_Integrations.md
Network isolation	§2, §4 — loopback server, CSP, isolated partitions
Open-core / source review	Available on request; behaviors verifiable in source
Sandbox execution / Windows Event Log review	Supported in the agency environment on request

10. Verification & contact

All architecture claims are verifiable in the published, signed source (`electron-main.js`, `preload.js`, `modules/security.js`, `modules/audit-log.js`, `modules/trace-search-api.js`, and page CSP headers). Intellect LE will walk an agency's technical team through the code, provide packet/payload captures, an SBOM, and code-signing attestation, and support sandbox execution and Windows Event Log review in the agency's environment.